Luxe By Madiha IT Rules and Regulations Policy

Oct 19, 2026 · @Madiha Diwan

1. Purpose, Scope and Document Control

This policy sets the rules for using Luxe By Madiha's technology safely, so customer data, stock records, financial information and the brand's reputation stay protected. It applies to all 11 roles, to interns and contractors, and to any device, account or network used for company work, including personal phones.

Most rules apply to everyone. Where a rule is the responsibility of one role, the role is named. Limits and time periods are proposed defaults that the Owner confirms at approval (Section 9).

Item	Detail
Document no.	LBM-IT-POL-001
Title	IT Rules and Regulations Policy
Version	1.0, draft for approval
Document owner	IT Manager
Reviewer	CEO
Approver	Owner
Effective date	Date of the Owner's signature
Next review	12 months after the effective date
Related documents	General Office SOPs (LBM-SOP-GEN-001) and the Security Manager's physical security procedures

2. Acceptable Use: Computers, Internet, Email and Messaging

Company technology is for company business. Limited personal use is allowed during breaks if it does not slow systems, break a rule below or create risk.

Computers and devices

- Use only the computer or device assigned to you by the IT Manager. Do not let others use it, including family and friends.
- Lock your screen whenever you leave your desk. Screens lock automatically after 5 minutes of inactivity.
- Do not disable antivirus, firewalls or updates, and do not connect unknown USB drives or chargers.
- Report a lost, stolen or damaged device to the IT Manager at once.

Internet

- Use the internet for work, research, supplier portals, marketplaces and approved social media.
- Do not visit or download from sites that are illegal, pornographic, gambling, hateful or known for malware, or stream long video or music during work hours.
- Company internet is monitored for security. Personal passwords entered on personal sites should not be stored on company devices.

Official email

- Use your company email address for all company business. Do not use personal email for customer, supplier or financial matters.
- Do not auto-forward company email to personal accounts.
- Send customer lists, price lists and financial documents only to people who need them, and check the recipient's address before sending.
- Use a clear subject line and the company signature. Do not send chain letters, jokes or political messages.
- Email is company property. The company may access it for security, legal or compliance reasons.

Messaging and social media

- Use the official company WhatsApp Business account and approved team chat for work. Do not share customer data or confidential files in personal chats or groups.
- Official social media accounts are used only by the Marketing Executive and people the CEO authorizes.

- Do not post confidential information, customer details or unreleased collections on any platform, including personal accounts.

3. Passwords and Multi-Factor Authentication

Every account has a unique, strong password, and multi-factor authentication (MFA) is switched on wherever the service offers it.

Rule	Standard
Length	At least 12 characters. A passphrase of 4 or more unrelated words is encouraged.
Uniqueness	A different password for every account. Never reuse a personal password for company work.
Storage	Use the company-approved password manager. Do not write passwords on paper, sticky notes or in chat.
Sharing	Never share a password, including with the IT Manager. Shared accounts such as the company social media pages use the password manager's sharing feature.
Changes	Change a password at once if it may be exposed. Routine forced changes are not required if the password is strong and unique.
Default passwords	Change every default password on routers, cameras, point-of-sale systems and new accounts on first use.
Lockout	Accounts lock after 5 failed attempts. The IT Manager unlocks them after confirming the employee's identity.

Where MFA is required

- Company email and the team chat or file storage service.
- Online banking, payment gateways and accounting software, which are limited to the Finance Director and named users.

- The e-commerce store admin, marketplace seller accounts and official social media accounts.
- Any remote access to company systems.

Use an authenticator app in preference to SMS codes. Keep MFA recovery codes in the password manager, and tell the IT Manager if you change your phone. Where a system offers no MFA, the IT Manager records it as an exception and reviews it every quarter.

4. Software, Licensing, Devices and Remote Access

Only the IT Manager installs software, and only licensed, approved software runs on company devices.

Software and licensing

1. Ask the IT Manager for any new software, stating the business need. The IT Manager checks security, cost and licensing, and the CEO approves purchases.
2. The IT Manager keeps a software register listing each product, licence type, number of seats, owner and renewal date.
3. Pirated, cracked or unlicensed software is prohibited. Free software is installed only if the IT Manager approves its source and licence terms.
4. Browser extensions, mobile apps and online tools that handle company data count as software and need the same approval.
5. Updates and security patches are installed within 7 days of release, and critical patches within 48 hours.

Company and personal devices

Device type	Rule
Company laptops and desktops	Registered by name, disk encryption on, antivirus running, screen lock set. Not used for personal storage or other people's work.
Company phones and tablets	Company accounts only, PIN or biometric lock, remote wipe enabled.

Device type	Rule
Personal phones used for work (BYOD)	Allowed only for email, team chat and MFA apps. The device needs a screen lock and current updates, and the IT Manager may remove company data from it if it is lost or the employee leaves.
Personal laptops and USB drives	Not allowed to store or process company data.

Remote access

- Remote work is allowed only with line manager approval (see the General Office SOPs).
- Connect only to company systems through the approved secure connection, with MFA on.
- Do not work on company data from public computers or shared devices. Avoid public Wi-Fi unless a secure connection is active.
- Keep your screen out of sight of others in public places.
- The IT Manager reviews remote access accounts every quarter and disables unused ones.

5. Data Access, Storage, Sharing, Backup and Retention

Staff get the minimum access their job needs, and company data lives only in approved company storage.

Data classes and who may access them

Class	Examples	Who may access	Rules
Restricted	Payment and bank details, payroll, HR and disciplinary files, passwords, supplier contracts	Named people only: Owner, CEO, Finance Director, HR / Sales / Marketing Manager as relevant	Encrypted storage, no sharing by chat or personal email, access logged

Class	Examples	Who may access	Rules
Confidential	Customer names, phone numbers and addresses, order history, stock and price lists, unreleased collections	Sales, Operations and management roles that need it	Company storage only, share by named-person link, no public links
Internal	SOPs, meeting minutes, rotas, marketing drafts	All employees	Company storage, not shared outside without approval
Public	Published website, social posts, product photos	Anyone	Approved by the Marketing Executive before release

Access permissions

1. Each new account is requested in writing by the line manager, listing the systems and access level needed.
2. The IT Manager grants access by role, with no shared logins, and records it in the access register.
3. Changes in role need a new request, and the old access is removed.
4. The IT Manager and Documentation & Compliance Coordinator review all access every quarter, and managers confirm that their staff's access is still needed.
5. Only the IT Manager holds administrator rights, and admin accounts are separate from daily-use accounts.

Storage and sharing

- Save company files in the approved cloud storage and shared drives, not on desktops, personal drives or removable media.
- Share with named people, not "anyone with the link". Remove sharing when the task ends.
- Send restricted data only through the approved secure method, never through personal messaging apps.
- Customer data is collected only for orders, delivery and service, and is not sold or used for other purposes without consent.

- Print only when needed, collect printouts at once and shred confidential papers.

Backup and retention

Item	Standard
Backup frequency	Cloud storage and e-commerce data backed up daily, and accounting data after every close
Backup copies	3 copies on 2 different media, with 1 stored off site or in the cloud
Protection	Backups are encrypted and use an account separate from daily-use accounts
Restore test	The IT Manager tests a restore every quarter and records the result
Financial and tax records	6 years
Customer and order records	2 years after the last order
Employee records	3 years after the employee leaves
Email and chat	3 years
CCTV footage	30 days, unless held for an incident

Retention periods are proposed defaults. The Finance Director confirms the legal minimum for financial and tax records, and the Documentation & Compliance Coordinator keeps the retention schedule. Expired records are deleted or shredded, and deletion is logged.

6. Phishing, Malware and Privacy

Pause before you click. Most attacks on small retailers start with a message that looks routine.

Spot phishing

Treat a message as suspicious if it:

- Creates urgency, such as "pay now", "account will be closed" or "urgent order".

- Asks for a password, MFA code, bank details or a payment to a new account.
- Comes from a sender whose address is slightly different from the real one.
- Contains an unexpected attachment, a shortened link or a login page reached from a link.
- Claims to be the Owner, CEO, a courier, a bank or a supplier, but asks for something unusual.

What to do

1. Do not click, open the attachment, reply or forward it.
2. Report it to the IT Manager using the Report Phishing button or by forwarding to the IT Manager's mailbox.
3. If you already clicked or entered details, tell the IT Manager at once and change the password (Section 7).
4. Verify any change of supplier bank details or payment request by calling a known number, not the number in the message. The Finance Director must approve the change.
5. Customer payment screenshots and "proof of payment" messages are checked in the bank or gateway account before an order ships.

Malware prevention

- Antivirus and the firewall stay on and updated. The IT Manager monitors alerts.
- Open files only from known senders and scan downloads before opening.
- Do not use cracked software, unknown USB drives or unapproved browser extensions.
- Disconnect an infected device from the network and call the IT Manager. Do not try to clean it yourself.
- The IT Manager runs phishing awareness training for all staff when they join and every year, and sends a short phishing test every quarter.

Privacy

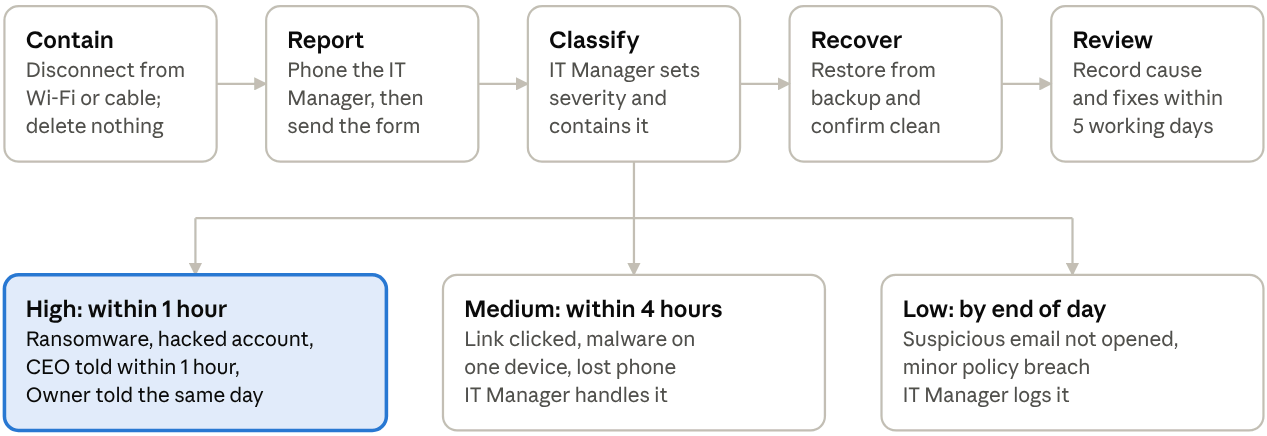
- Collect only the customer information needed to process an order, and tell customers why we collect it.
- Use customer data only for the purpose it was collected for. Marketing messages go only to customers who agreed to receive them, with an easy way to opt out.

- Do not look up customer or colleague records out of curiosity. Access is logged and reviewed.
- Customers can ask to see, correct or delete their data. Pass the request to the Documentation & Compliance Coordinator, who replies within 30 days.
- Staff personal data is held by the HR / Sales / Marketing Manager and shared only as needed or as the law requires.
- Where a law sets a stricter privacy rule, the law applies.

7. Incident Reporting

Report any suspected security incident to the IT Manager immediately, even if you are unsure or made the mistake yourself. Prompt reports are never punished, and delays make incidents worse.

Report first, then the IT Manager sets severity and the response



incident response · 5 steps, 3 severity levels

The tables and steps below give the detail for each severity level and each step.

Severity	Examples	Report within	Who leads
High	Ransomware, hacked email or payment account, stolen device holding customer data, customer data leak	1 hour of noticing	IT Manager, with the CEO told within 1 hour and the Owner the same day

Severity	Examples	Report within	Who leads
Medium	Link clicked with details entered, malware on one device, lost phone with company email	4 hours	IT Manager
Low	Suspicious email not opened, forgotten MFA device, minor policy breach	End of the working day	IT Manager

1. **Contain.** Disconnect the device from Wi-Fi and cable. Do not switch it off, delete anything or try to fix it.
2. **Report.** Phone the IT Manager first, then send the Incident Report: date and time, your name, the device or account, what happened and what you have done. If the IT Manager is unavailable, call the CEO.
3. **Classify and act.** The IT Manager classifies the severity, resets affected passwords, ends active sessions, isolates devices and preserves evidence.
4. **Notify.** The CEO decides who else must be told. The Finance Director contacts the bank or payment provider for any payment-related incident. Customers, authorities or insurers are informed where a law or contract requires it, and the Documentation & Compliance Coordinator checks those duties.
5. **Recover.** The IT Manager restores systems from backup and confirms the threat is gone before normal work resumes.
6. **Review.** Within 5 working days, the IT Manager records the cause, impact and fixes in the incident register and tells staff what changes.

A lost or stolen device is also reported to the Security Manager if it was taken from the premises. Physical break-ins are handled under the Security Manager's procedures.

8. Access Removal When Staff Leave

All access ends at the moment employment ends, and no later than the end of the last working day. For dismissals or security concerns, access is removed before the employee is told.

The HR / Sales / Marketing Manager tells the IT Manager, Finance Director and Security Manager the same day a resignation is received or a termination is decided. The IT Manager then works through the checklist below and signs it off.

When	Action	Owner
On notice	Confirm last working day. Start the exit checklist. Remind the employee of confidentiality duties.	HR / Sales / Marketing Manager
Before the last day	Move the employee's files, customer contacts and open tasks to a named colleague. Review company data on personal phones.	Line manager
Last working day	Disable the email account, team chat, cloud storage, e-commerce admin, marketplace and remote access. End all active sessions. Reset MFA.	IT Manager
Last working day	Remove the employee from bank, payment gateway and accounting access. Cancel company cards and pending claims.	Finance Director
Last working day	Collect laptop, phone, chargers, ID badge, access card and keys. Cancel stock room and premises access.	Security Manager
Last working day	Wipe company data from any personal device used for work. Wipe company devices before reuse.	IT Manager
Within 24 hours	Change shared passwords the employee knew, including social media pages, supplier portals and the Wi-Fi password if shared. Remove the person from the password manager and group chats.	IT Manager

When	Action	Owner
Within 7 days	Set the mailbox to forward to the line manager or a shared mailbox for 30 days, then archive it. Transfer ownership of documents.	IT Manager
Within 30 days	Check logs for sign-ins after the exit date. File the signed checklist in the employee record.	IT Manager, Documentation & Compliance Coordinator

- **Exit confidentiality.** The employee confirms in writing that they will keep customer data, pricing and supplier information confidential after they leave.
- **Role changes.** When an employee moves to a new role, the old access is removed within 2 working days, following Section 5.
- **Contractors and interns.** Accounts are created with an end date and disabled automatically on that date.
- **Unreturned equipment.** The HR / Sales / Marketing Manager follows up in writing, and the CEO decides on recovery of the cost.

9. Roles, Enforcement, Review and Acknowledgment

The IT Manager owns this policy, and every employee is responsible for following it.

Role	IT responsibilities
Owner	Approves this policy and any exceptions the CEO escalates
CEO	Approves software purchases, decides external notifications after a serious incident
IT Manager	Runs systems, accounts, backups, patches, software register, access reviews and the incident register
Security Manager	Protects devices and the stock room physically, and handles lost or stolen equipment
Finance Director	Controls payment accounts and verifies any change to supplier bank details

Role	IT responsibilities
HR / Sales / Marketing Manager	Tells the IT Manager of joiners, movers and leavers, and runs the disciplinary process
Documentation & Compliance Coordinator	Keeps the policy, retention schedule and acknowledgments, and checks legal duties
Marketing Executive	Controls official social media content and accounts
All other staff	Follow this policy, complete training, and report incidents at once

Monitoring, enforcement and exceptions

- The company may monitor company systems, email and internet use for security and legal reasons, and will not read personal messages beyond what is needed for this purpose.
- Breaches are handled under the disciplinary process in the General Office SOPs (Section 11). Deliberate data theft, unauthorized access or sabotage can lead to dismissal and legal action.
- An exception needs a written request to the IT Manager, approval by the CEO, an end date and a record in the exception register.

Review and approval

The IT Manager reviews this policy every 12 months and after any high-severity incident. Changes follow the change request process in the General Office SOPs (Section 12). The Documentation & Compliance Coordinator updates the version number, archives the old copy and collects acknowledgments. The Owner approves every new version.

Acknowledgment

I have read and understood the Luxe By Madiha IT Rules and Regulations Policy (LBM-IT-POL-001) and agree to follow it.

Field	Entry
Name and role	

Field	Entry
Version acknowledged	
Signature	
Date	

Revision history

Version	Date	Change	Approved by
1.0	Pending approval	First issue	Owner